

Data Security

Master's in Cybersecurity

João Marco Silva

Department of Informatics
joaomarco@di.uminho.pt

University of Minho
School of Engineering

Data Security

Objectives

- Understand the main concepts related to data security
- Understand the interrelation of security properties across heterogeneous computer systems and application domains
- Understand the main threats and attacks to digital data
- Understand the relationship between security properties, threats, vulnerabilities, weaknesses, and attacks
- Explore public databases containing security-relation information

Data Security

Global panorama

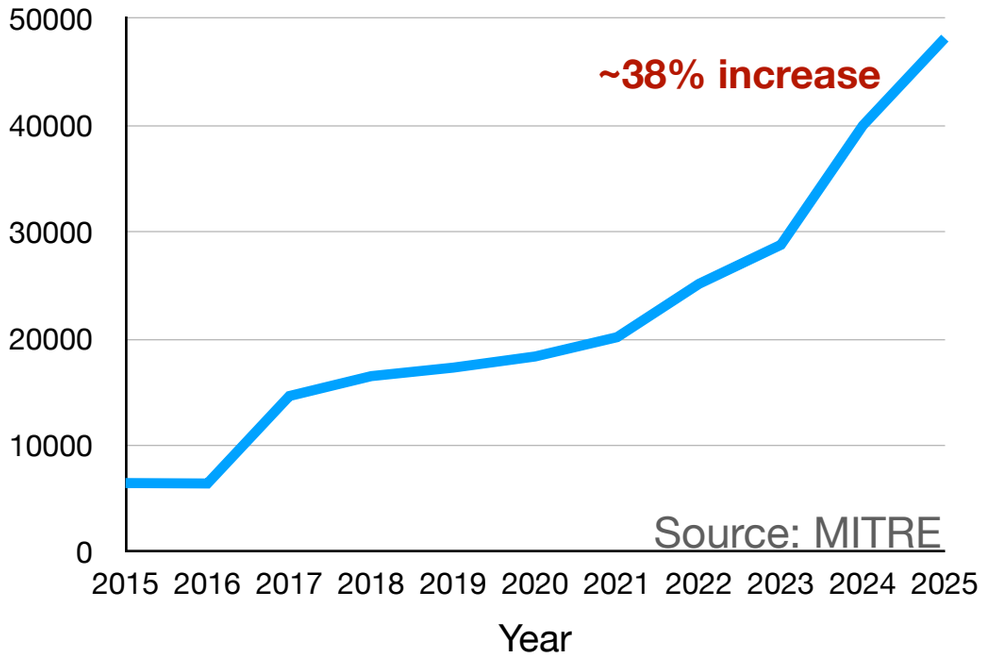
The annual global cost of cybercrime reached $10.5 trillion in 2025

Source: World Economic Forum

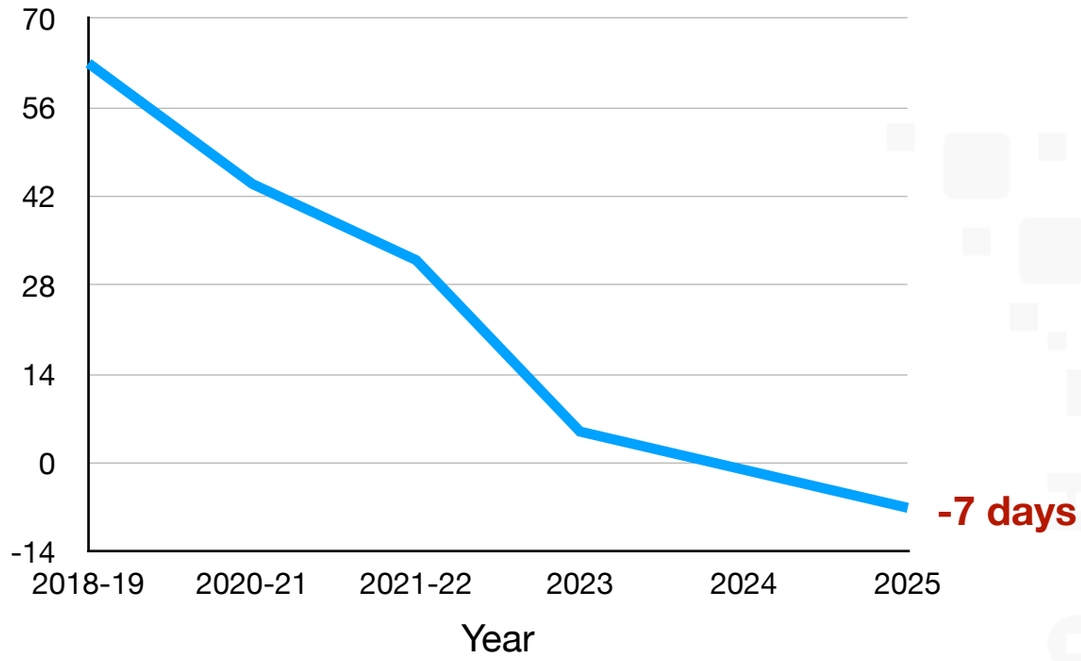
Exploitation of software vulnerabilities accounted for 20% of all intrusion incidents in early 2025

Source: VulnCheck

Number of published vulnerabilities per year



Average time-to-exploit in days

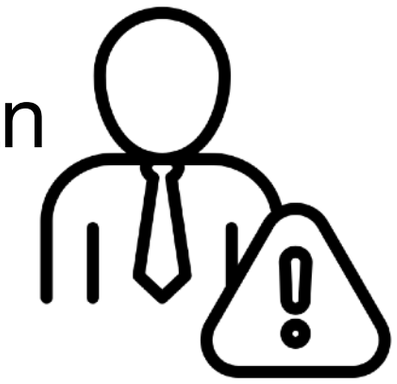


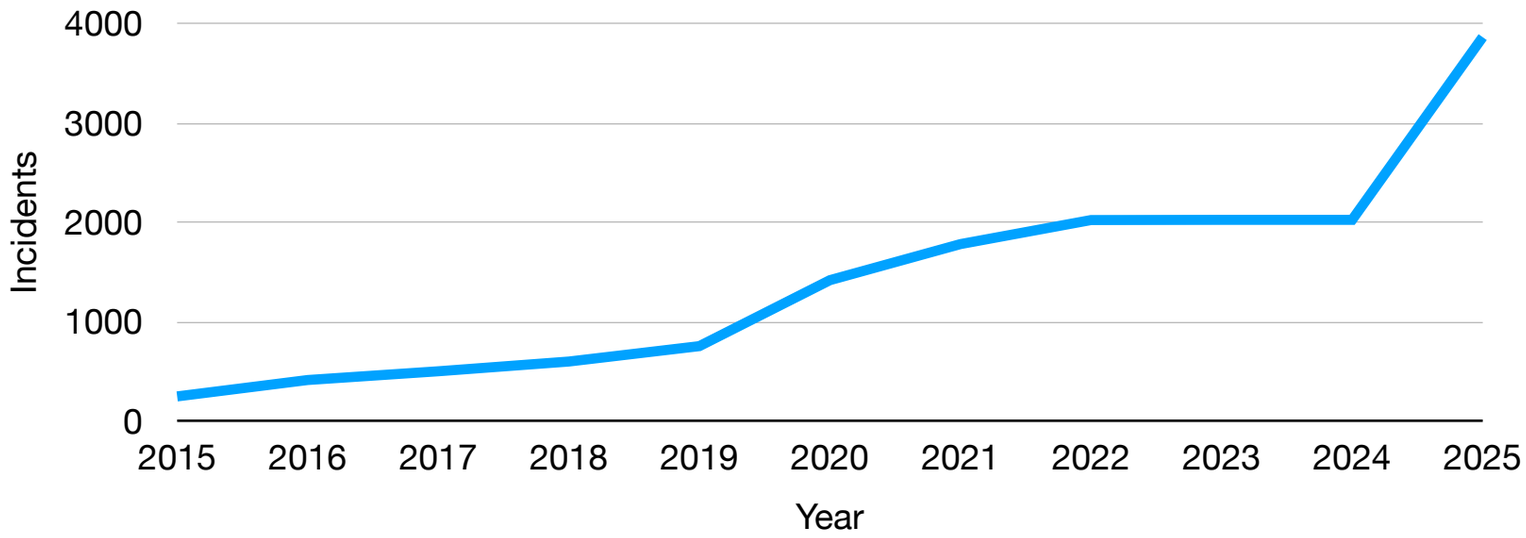
Data Security

Panorama: Portugal

Over the last five years, CERT.PT* registered a 268% increase in the number of cybersecurity incidents

The most frequent sources of incidents are human error (23%), vulnerability exploitation (21%), and ransomware (15%)





Source: CERT.PT

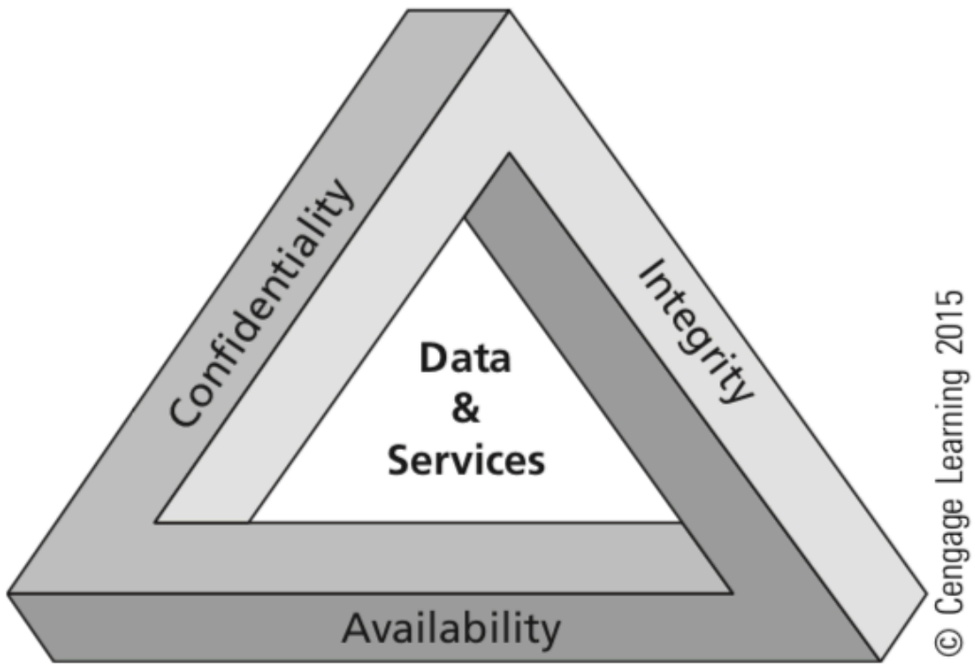
***Computer Emergency Response Team (CERT)**

Data Security

Concepts

What is information security?

The protection of information/data and its critical elements, including the systems and hardware used to process, store, and transmit the information*.



The C.I.A. triangle

* Source: The Committee on National Security Systems (CNSS)

Data Security

Concepts



- **Confidentiality**
  - ensures that only users/systems with the rights and privileges to access data are able to do so.



- **Integrity**
  - ensures the consistency of information.
    - involves maintaining data accuracy, completeness, and trustworthiness over its entire life cycle.



- **Availability**
  - ensures authorised users/systems access data without interference or obstruction

Data Security

Concepts

Security properties are context-dependent



- **Non-repudiation / accountability**
  - ensures for actions of an entity to be traced uniquely to that entity

- **Authenticity**
  - ensures that data and services are genuine, verifiable, and trusted

Data Security

Concepts

Asset: resources being protected, *e.g.*, hardware, software, data, networks, reputation, etc.

Vulnerabilities: a weakness or fault in a system or protection mechanism that opens it to attack or damage. It also includes misconfiguration.

Threat: a category of object, people, or other entities that represents a danger to an asset.

Attack: an intentional act that can damage or otherwise compromise information and the systems that support it.

Exploit: a technique used to compromise a system.

Data Security

Concepts

Information Security

The protection of information, which is an asset, from possible harm resulting from various threats and vulnerabilities

Cybersecurity

It is not necessarily only the protection of cyberspace itself but also the protection of those that function in cyberspace and any of their assets that can be reached via cyberspace

- Cyberbullying
- Cyber terrorism
- Copyrights



they are not related to the CIA

Data Security

Concepts

Attack surfaces: Reachability and exploitability of system's vulnerabilities

- Network attack surface
- Software attack surface
- Human attack surface

Vulnerabilities

A weakness or fault in a system or protection mechanism that opens it to attack or damage.

Do you know all the vulnerabilities your personal system is exposed to, right now?



Vulnerabilities

Kernel

The most severe vulnerability in this section could lead to local escalation of privilege in the kernel with no additional execution privileges needed.

CVE	References	Type	Severity	Subcomponent
CVE-2024-46852	A-363259128 Upstream kernel [2]	EoP	High	dma-buf
CVE-2024-50302	A-380395346 Upstream kernel [2]	ID	High	HID
CVE-2025-22413	A-373638114 Upstream kernel [2]	ID	High	KVM

Android’s security bulletin - March 2025

Vulnerabilities

CVE/CVSS

- CVE - Common Vulnerabilities and Exposures
  - a list of standardised names for vulnerabilities and other information related to publicly known security exposures
- CVE is maintained by MITRE Corporation, which is also responsible for moderating the Editorial Board
  - *cve.mitre.org*
  - *nvd.nist.gov - National Vulnerability Database*



Vulnerabilities

CVE/CVSS

CVSS - Common Vulnerability Scoring System

Impact

CVSS v3.0 Severity and Metrics:

Base Score: 7.0 HIGH

Vector: AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H (V3 legend)

Impact Score: 5.9

Exploitability Score: 1.0

Attack Vector (AV): Local

Attack Complexity (AC): High

Privileges Required (PR): Low

User Interaction (UI): None

Scope (S): Unchanged

Confidentiality (C): High

Integrity (I): High

Availability (A): High

Rating	CVSS Score
None	0.0
Low	0.1 - 3.9
Medium	4.0 - 6.9
High	7.0 - 8.9
Critical	9.0 - 10.0

Vulnerabilities

CVSSv4

New metric group
- Not Defined (X)
- Attacked (A)
- Proof-of-Concept (P)
- Unreported (U)

Base Metric Group

Exploitability Metrics
- Attack Vector
- Attack Complexity
- Attack Requirements
- Privileges Required
- User Interaction

Impact Metrics
- Vulnerable System Confidentiality
- Vulnerable System Integrity
- Vulnerable System Availability
- Subsequent System Confidentiality
- Subsequent System Integrity
- Subsequent System Availability

Threat Metric Group
- Exploit Maturity

Environmental Metric Group

Modified Base Metrics
- Attack Vector
- Attack Complexity
- Attack Requirements
- Privileges Required
- User Interaction
- Vulnerable System Confidentiality
- Vulnerable System Integrity
- Vulnerable System Availability
- Subsequent System Confidentiality
- Subsequent System Integrity
- Subsequent System Availability

- Confidentiality Requirement
- Integrity Requirement
- Availability Requirement

Supplemental Metric Group
- Automatable
- Recovery
- Safety
- Value Density
- Vulnerability Response Effort
- Provider Urgency

Weaknesses

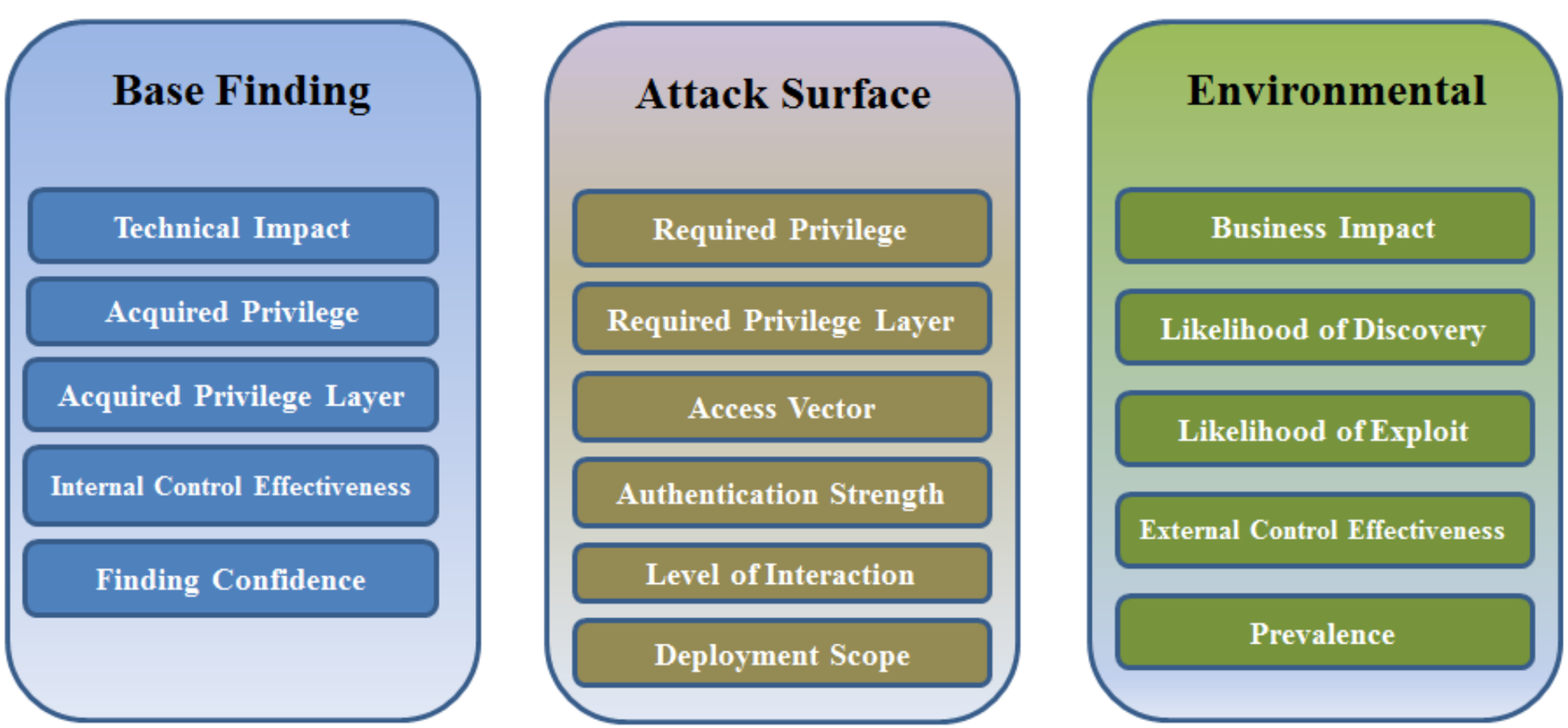
CWE

- **CWE - Common Weakness Enumeration**
  - Community-developed list of software an hardware weakness types
  - Category system
- A baseline for weakness identification, mitigation and prevention
- CWE List v4.2 https://cwe.mitre.org/data/

Weaknesses

CWE

- **CWE - Common Weakness Enumeration**
  - CWSS - Common Weakness Scoring System



Source: cwe.mitre.org/cwss/cwss_v1.0.1.html

Exploits

Public databases





packet storm







CXSECURITY

Data Security

Attacks

MITRE | ATT&CK®

Examples of common attacks

OWASP®

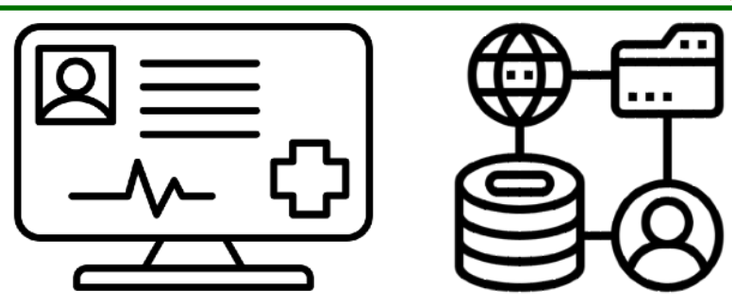
It's challenging to map and respond to attacks individually

DDoS Attack

IDS / IPS

Backups

Ransomware Attack



Electronic Health Record (EHR) System

Data availability is a critical requirement

Input validation

SQL Injection Attack

Data poisoning Attack

Physical Destruction

Threat Modeling

Concepts

A systematic process used to identify, quantify, and address security risks within applications, IT infrastructures, and business processes.

Goals:

- Identify and quantify security risks in critical assets
- Assist in clarifying security requirements
- Outline ways to mitigate or prevent these threats before they can be exploited

As of early 2025, the average time to explore a vulnerability is only 3 to 5 days following its public disclosure

Threat Modeling

Frameworks

- **STRIDE** - Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege
- **PASTA** - Process for Attack Simulation and Threat Analysis
- **DREAD** - Damage, Reproducibility, Exploitability, Affected Users, and Discoverability
- **LINDDUN** - Linking, Identifying, Non-repudiation, Detecting, Data Disclosure, Unawareness, and Non-compliance

Threat Modeling

STRIDE

Spoofing	Impersonating a user or system
Tampering	Modifying data or code
Repudiation	Denying performing an action
Information Disclosure	Exposing data to unauthorized users or systems
Denial of Service	Denying or degrading service to users or systems
Elevation of Privilege	Gaining capabilities without proper authorization

Threat Modeling

STRIDE



Violated security properties & Examples

Spoofing

➡ Authenticity

- Email spoofing
- DNS spoofing

Tampering

➡ Integrity

- Changing values in a DB
- Removing network packets

Repudiation

➡ Non-Repudiation

- Using untrusted certificates
- Neutralizing the log system

Information Disclosure

➡ Confidentiality

- Exposing sensitive data
- Leaky API responses

Denial of Service

➡ Availability

- Massive request to a DNS
- A process filling up the disk

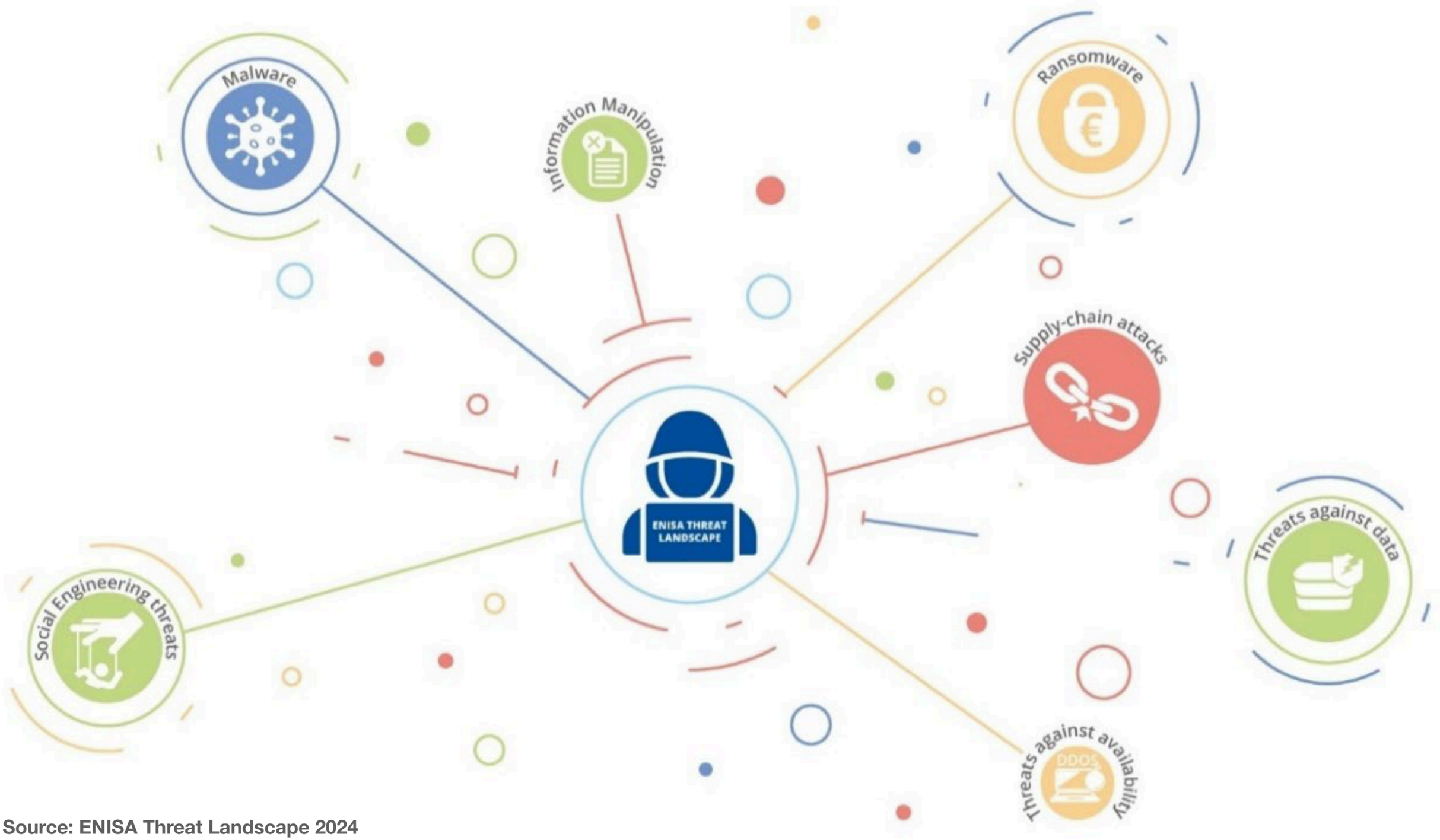
Elevation of Privilege

➡ Authenticity

- Improper root execution
- DLL hijacking

Data Security

Threat landscape



Source: ENISA Threat Landscape 2024



Data Security

Master's in Cybersecurity

João Marco Silva

Department of Informatics
joaomarco@di.uminho.pt

University of Minho
School of Engineering